INFORMATION GATHERING

- In the Art of War, Sun Tzu taught, “If you know the enemy and know yourself, your victory will not stand in doubt.”
- If you are playing the role of an attacker, you need to gather information about your target systems. If you are playing the role of a defender, you need to know what your adversary will discover about your systems and networks.

INFORMATION GATHERING

- Passive Reconnaissance
- Active Reconnaissance



PASSIVE RECONNAISSANCE

In passive reconnaissance, you rely on publicly available knowledge. It is the knowledge that you can access from publicly available resources without directly engaging with the target. Think of it like you are looking at target territory from afar without stepping foot on that territory.

Passive reconnaissance activities include many activities, for instance:

- Looking up DNS records of a domain from a public DNS server.
- Checking job ads related to the target website.
- Reading news articles about the target company.



ACTIVE RECONNAISSANCE

Active reconnaissance, on the other hand, cannot be achieved so discreetly. It requires direct engagement with the target. Think of it like you check the locks on the doors and windows, among other potential entry points.

Examples of active reconnaissance activities include:

- Connecting to one of the company servers such as HTTP, FTP, and SMTP.
- Calling the company in an attempt to get information (social engineering).
- Entering company premises pretending to be a repairman.



CYBERATTACK TYPES AND TECHNIQUES

- Phishing
- Malware
- Social Engineering
- Distributed Denial of Service (DDoS)
- Man-in-the-Middle (MitM)
- SQL Injection
- Cross-Site Scripting (XSS)



Phishing

- Phishing is a cyberattack method used by malicious actors to trick individuals into revealing sensitive information
- These attacks are typically carried out through deceptive communication

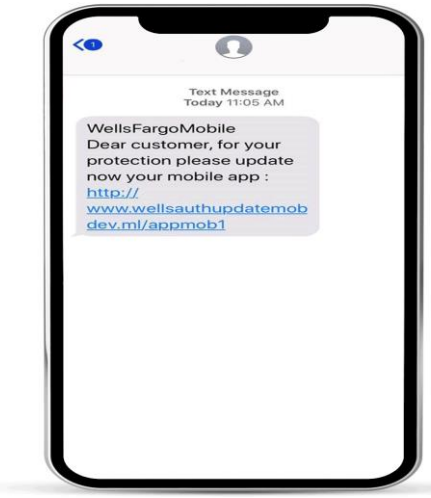
Vishing

- Vishing is phishing using voice communication
- Criminals want to obtain credit card numbers or other information to steal the victim’s identity.



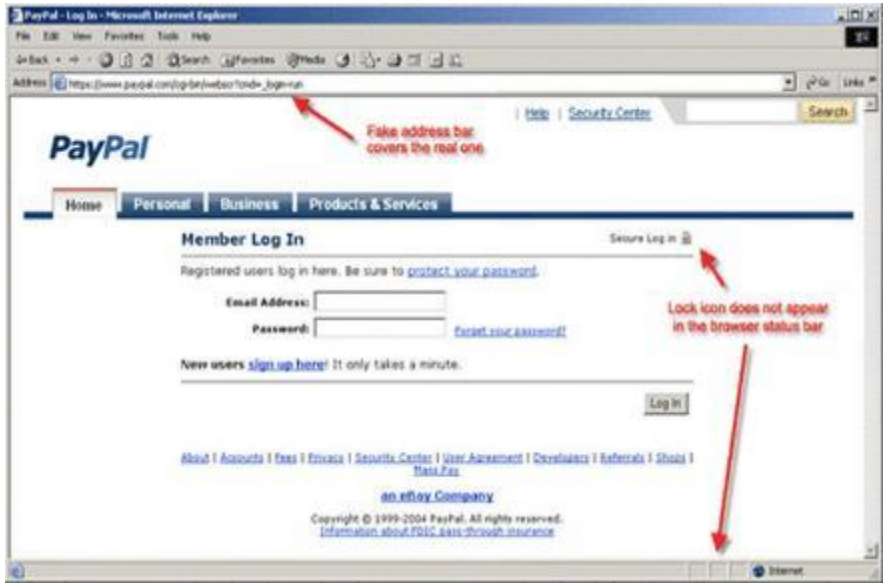
Smishing

- Smishing (Short Message Service phishing) is phishing using text messaging on mobile phones.
- For example, a smishing attack might send the victim a website link.



Pharming

- Pharming is the impersonation of a legitimate website in an effort to deceive users into entering their credentials.



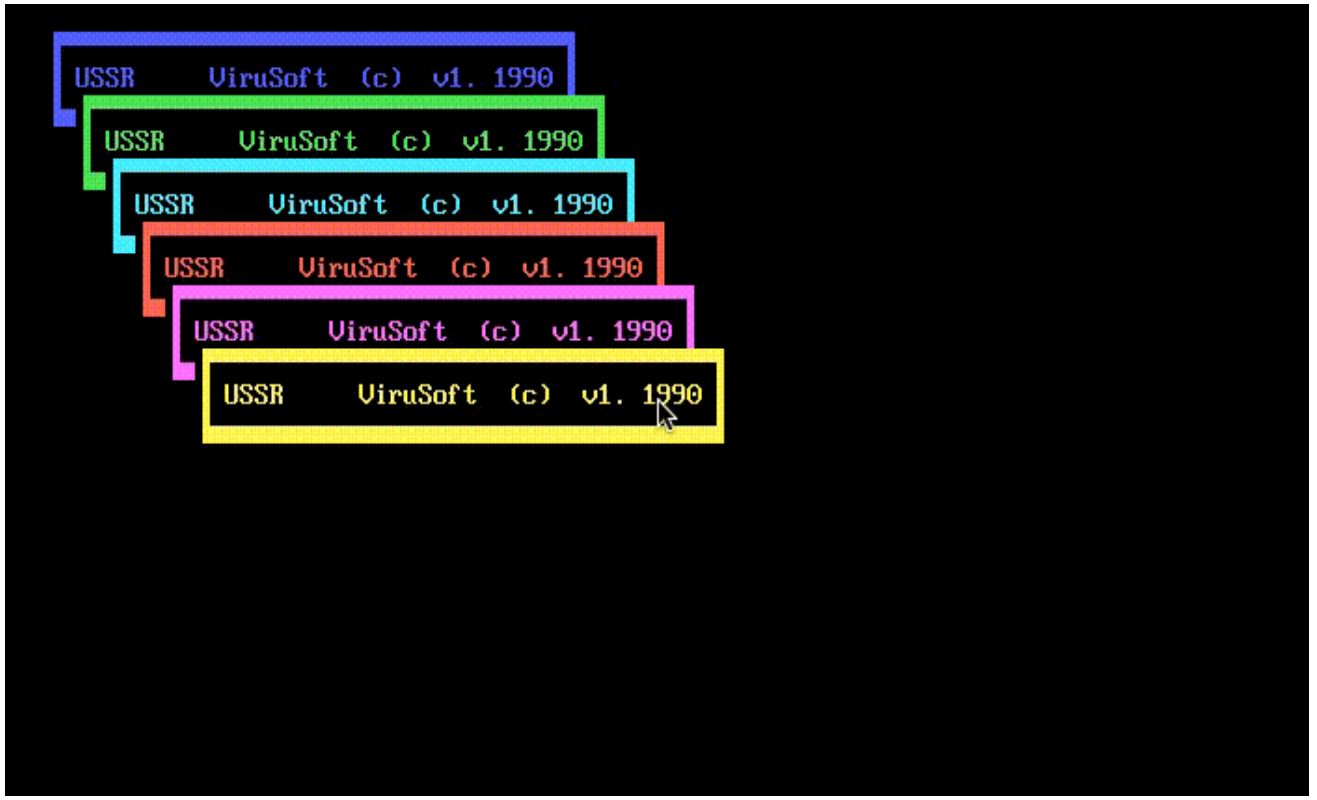
Whaling

- Whaling is a phishing attack that targets high profile targets
- Additional targets include politicians or celebrities.



WHAT IS MALWARE?

- Malicious software, or malware, is a term used to describe software designed to disrupt computer operations.



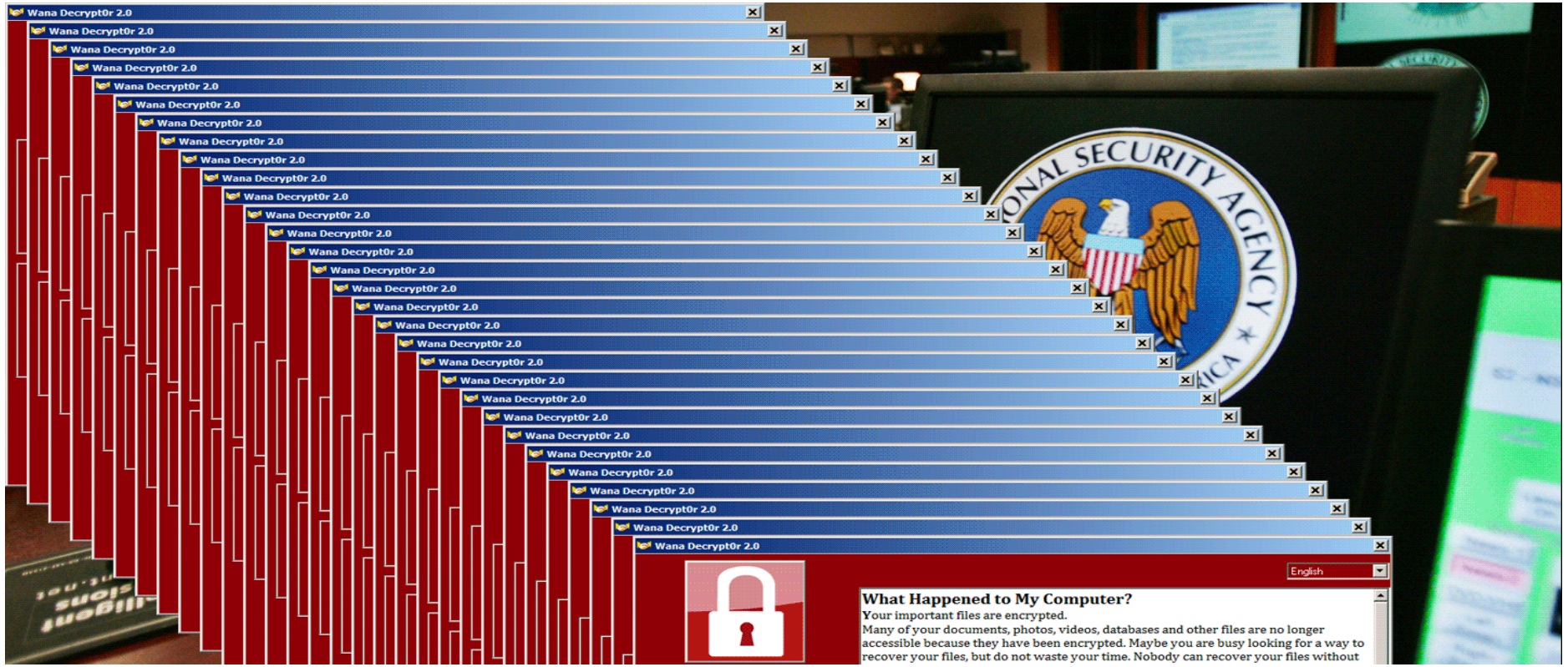
Types of Malware

- Malware includes computer viruses, worms, Trojan horses, ransomware, spyware, adware, scareware, and other malicious programs.



Virus

- A virus is malicious executable code attached to another executable file, such as a legitimate program.



Worms

- Replicates by independently exploiting vulnerabilities
- Slow down networks or Computer
- Run by themselves: Other than the initial infection, worms no longer require user participation



Trojan Horse

- Carries out malicious operations under the guise of a desired operation such as playing an online game.
- A Trojan horse differs from a virus because the Trojan binds itself to non-executable files, such as image files, audio files, or games.



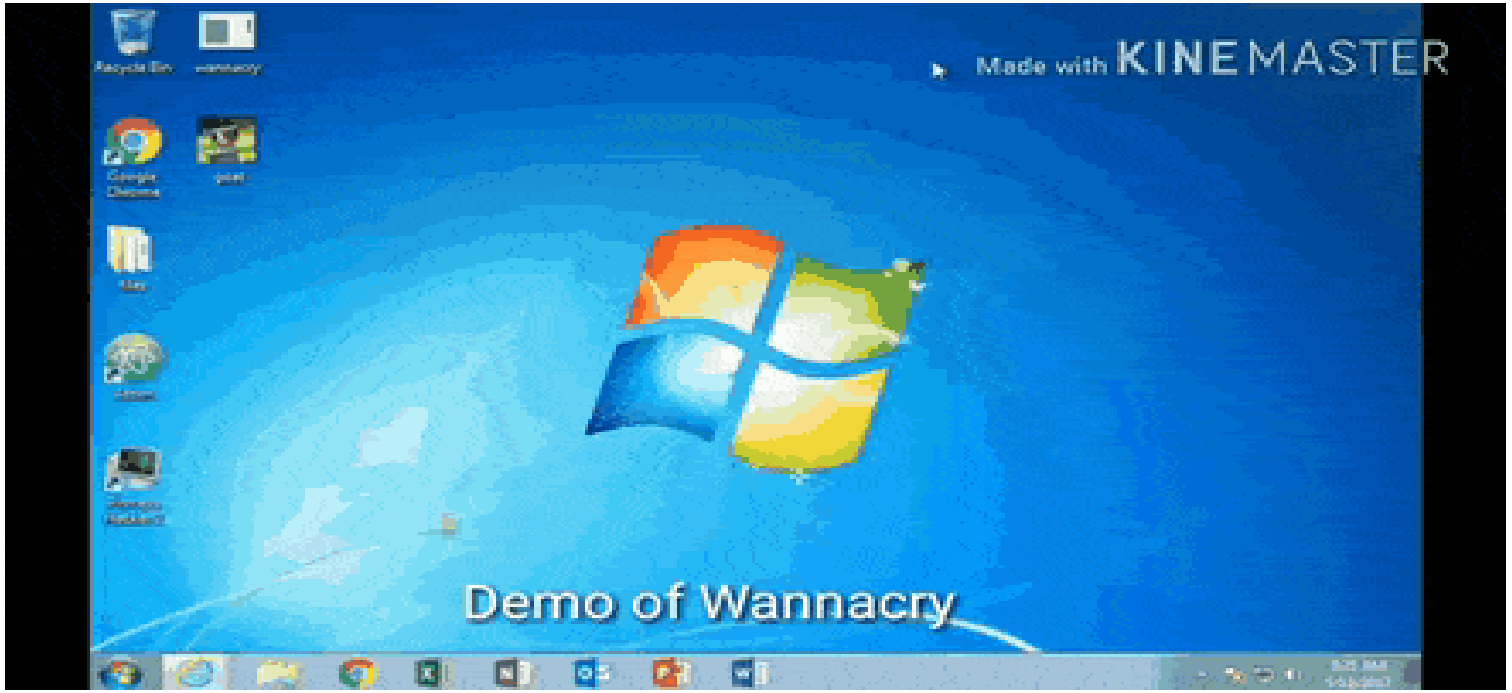
Logic Bombs

- A logic bomb is a malicious program that uses a trigger to awaken the malicious code.
- Fails hardware components.

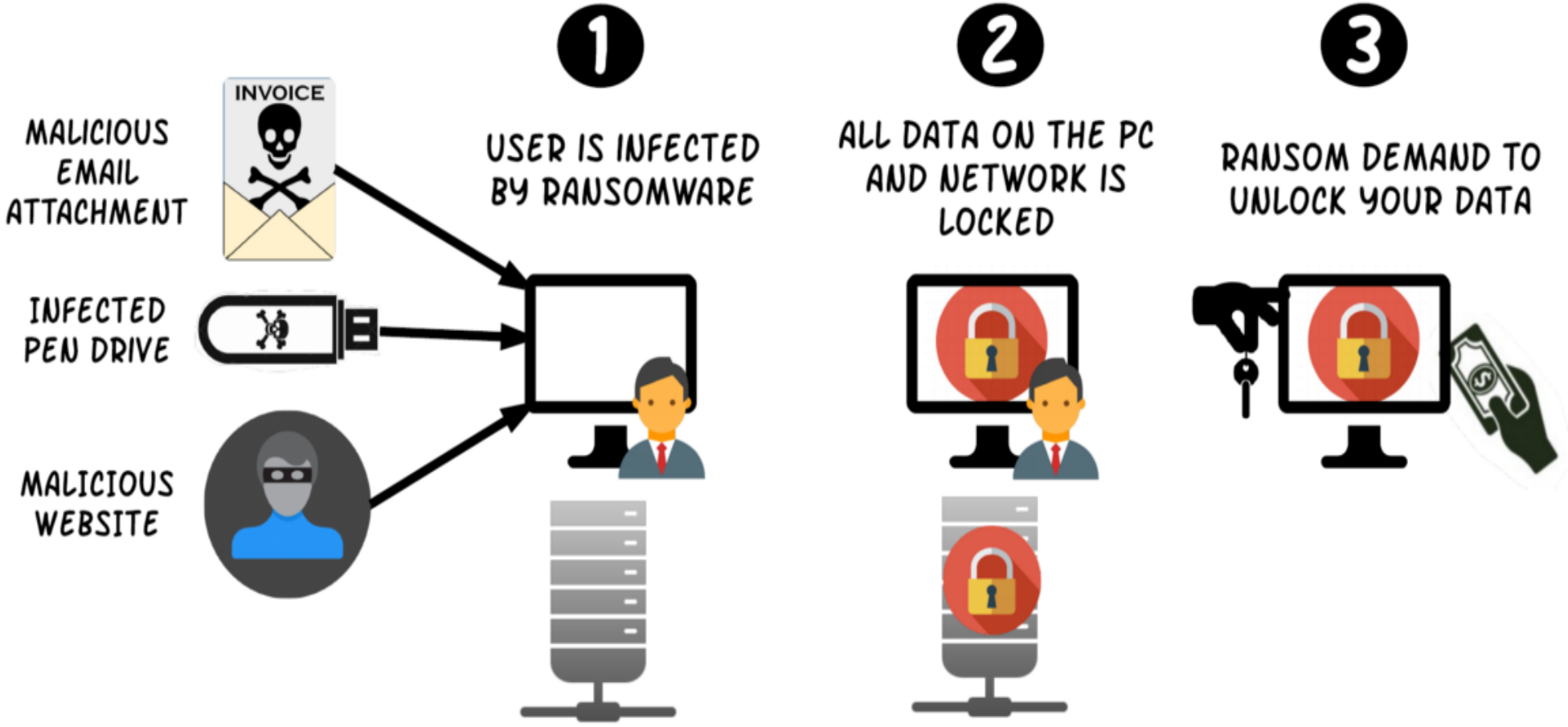


Ransomware

- Ransomware usually works by encrypting data in the computer with a key unknown to the user.
- Payment through an untraceable payment system is always the criminal's goal.



How Ransomware Works?



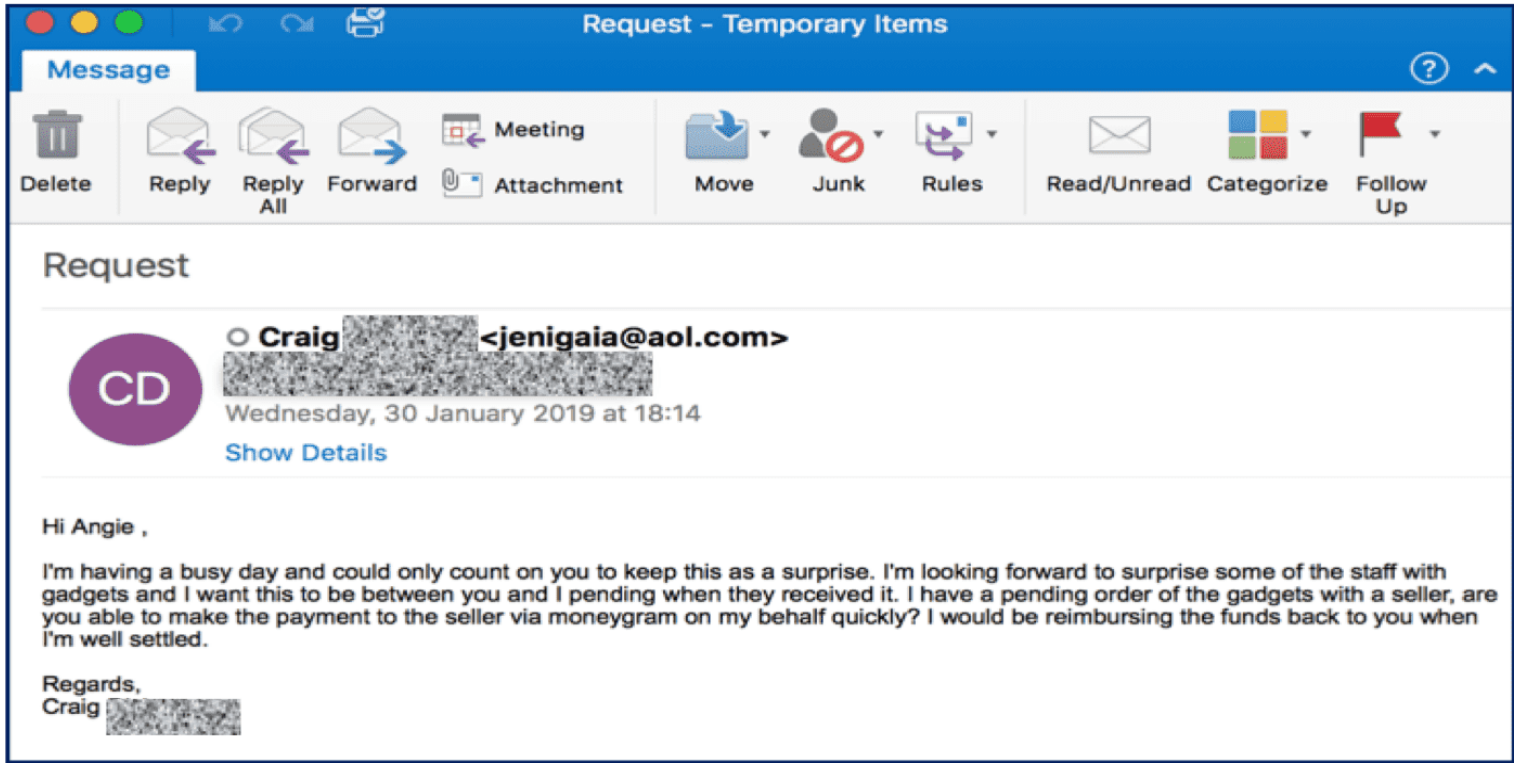


Social Engineering

- It used to manipulate individuals into divulging sensitive information, performing specific actions, or compromising their security.
- This type of attack exploits human psychology, trust, and natural behavior to gain unauthorized access to systems.

Hoaxes

- A hoax is an act intended to deceive or trick. A cyber hoax can cause just as much disruption as an actual breach would cause.
- Fake news: Hoaxes can use fake news to influence your opinion on certain topics.
- False virus alerts: Hoaxes can claim that a file is a virus or other harmful file, and instruct users to delete it.
- Fake competitions: Hoaxes can offer fake competitions or prizes to trick people.



Shoulder Surfing and Dumpster Diving

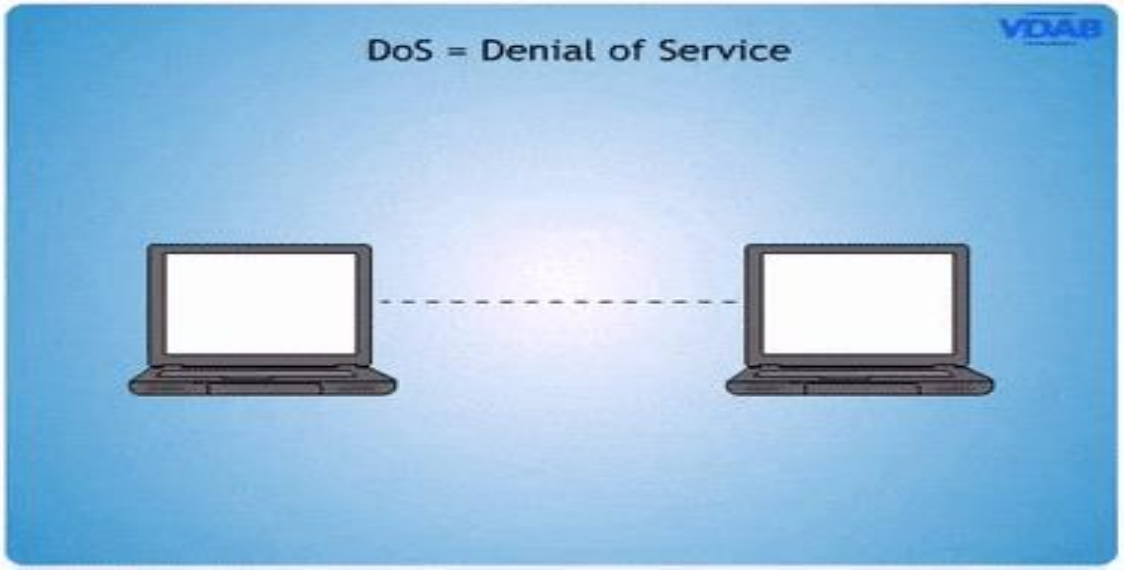
- A criminal observes, or shoulder surfs, to pick up PINs, access codes or credit card numbers.
- "One man's trash is another man's treasure". Any sensitive information should be properly disposed.





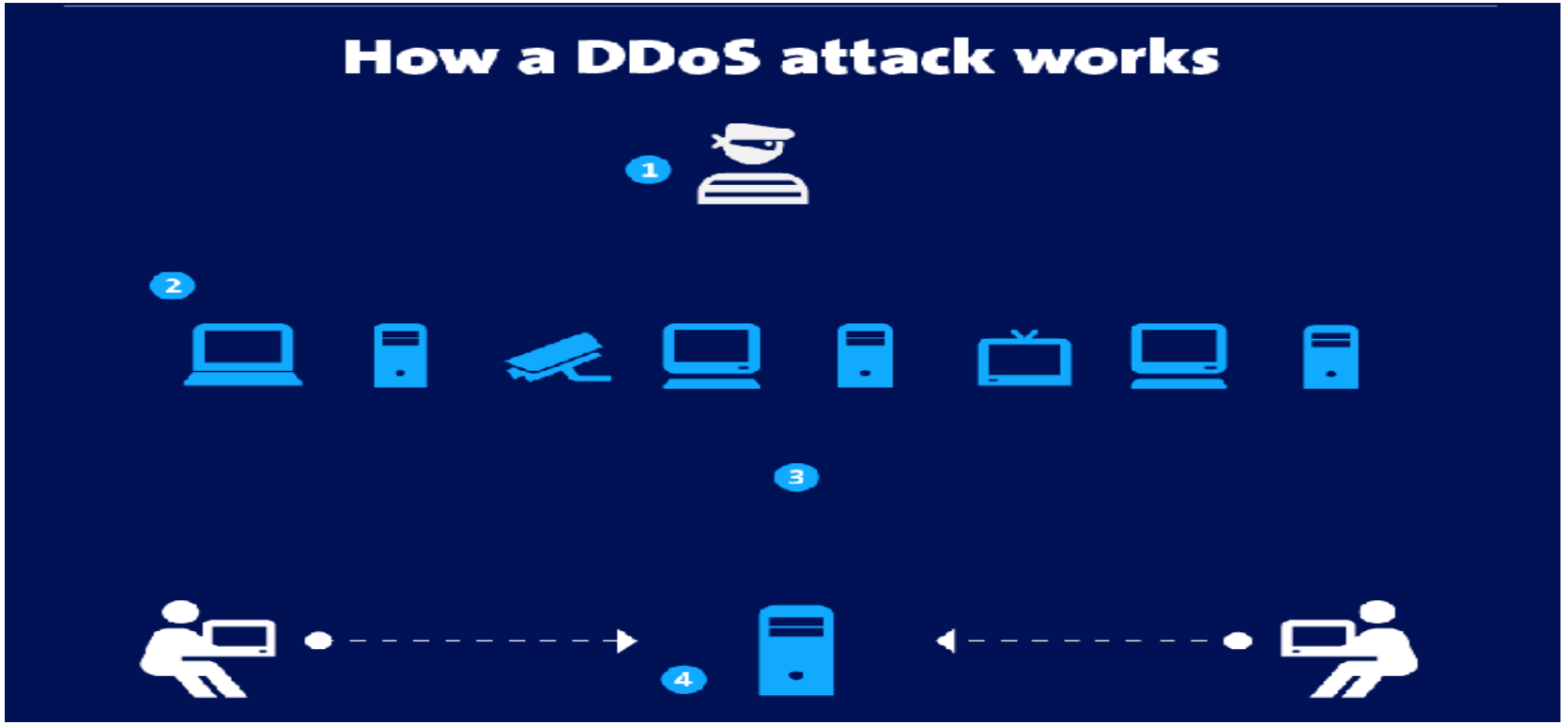
Denial of Service (DoS)

- Results in some sort of interruption of network services to users, devices, or applications.
- The goal of a denial-of-service attack is to deny access to authorized users making the network unavailable.



Distributed DoS Attack (DDoS)

- Similar to a DoS attack, but it originates from multiple, coordinated sources.
  - ➢An attacker builds a network of infected hosts, called a botnet (Zombies').





BOTS AND BOTNETS

BOTNET

- A botnet is a network of computers or devices
- Botnets have been compromised and are under the remote control of a single entity called botmaster.
- These compromised devices, often called bots or zombies.
- Malwares allows the botmaster to perform various actions without the knowledge of the device owners.
- Botnets can consist of thousands or millions of compromised devices.
- Compromised devices creating a powerful tool for the botmaster to carry out malicious activities.

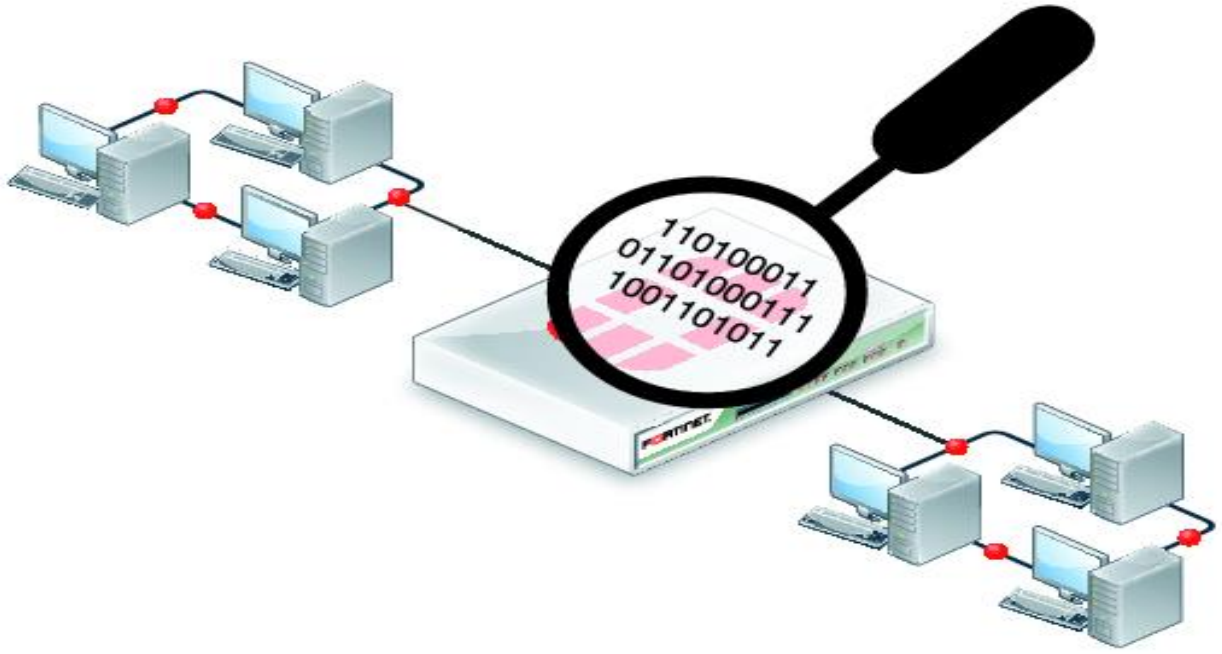


SQL Injection

- SQL injection is a type of cyberattack
- It occurs when an attacker maliciously inserts SQL code within input fields of a web application.
- This attack exploits vulnerabilities in poorly sanitized user inputs.
- It allows the attacker to execute unauthorized SQL queries on the application's database.
- The primary goal of an SQL injection attack is to gain unauthorized access to the database.

Sniffing

- It occurs when attackers **examine all network traffic** as it passes through their NIC, independent of whether or not the traffic is addressed to them or not.



Spoofing

- Spoofing is an impersonation attack, and it takes advantage of a trusted relationship between two systems.

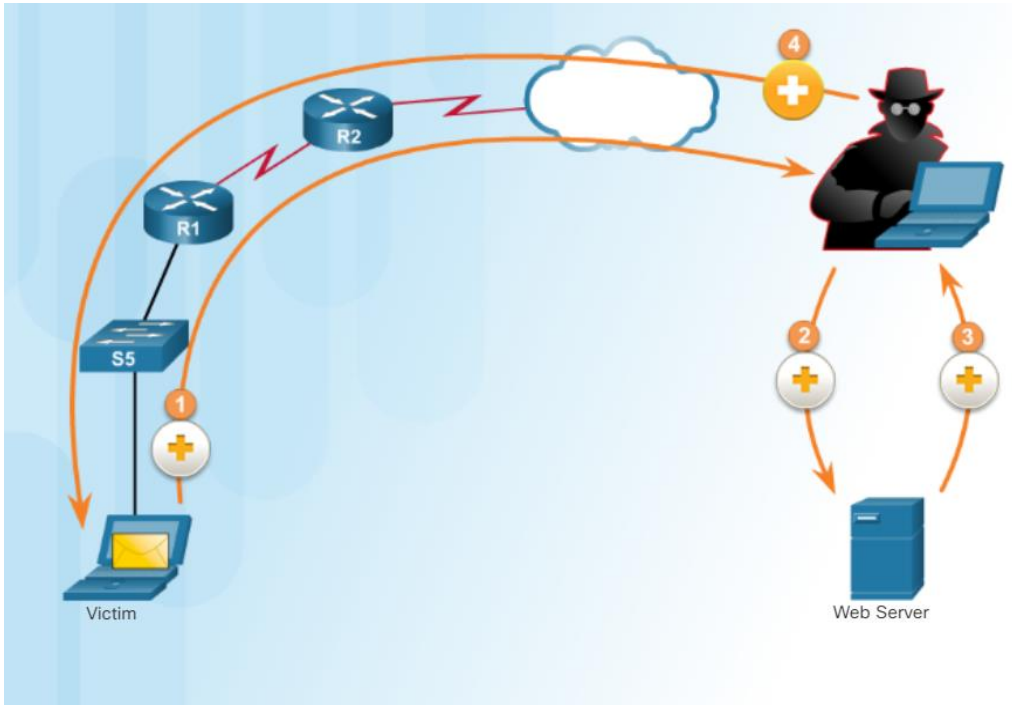
There are multiple types of spoofing attacks.

- MAC address spoofing
- IP spoofing



Man-in-the-middle attack example

- A criminal performs a man-in-the-middle (MitM) attack by intercepting communications between computers to steal information crossing the network.





Cross-Site Scripting (XSS)

- Cross-Site Scripting (XSS) is a type of security vulnerability.
- It occurs when a web application allows malicious users to inject malicious scripts.
- This vulnerability arises when the application does not properly validate content before displayed to users.



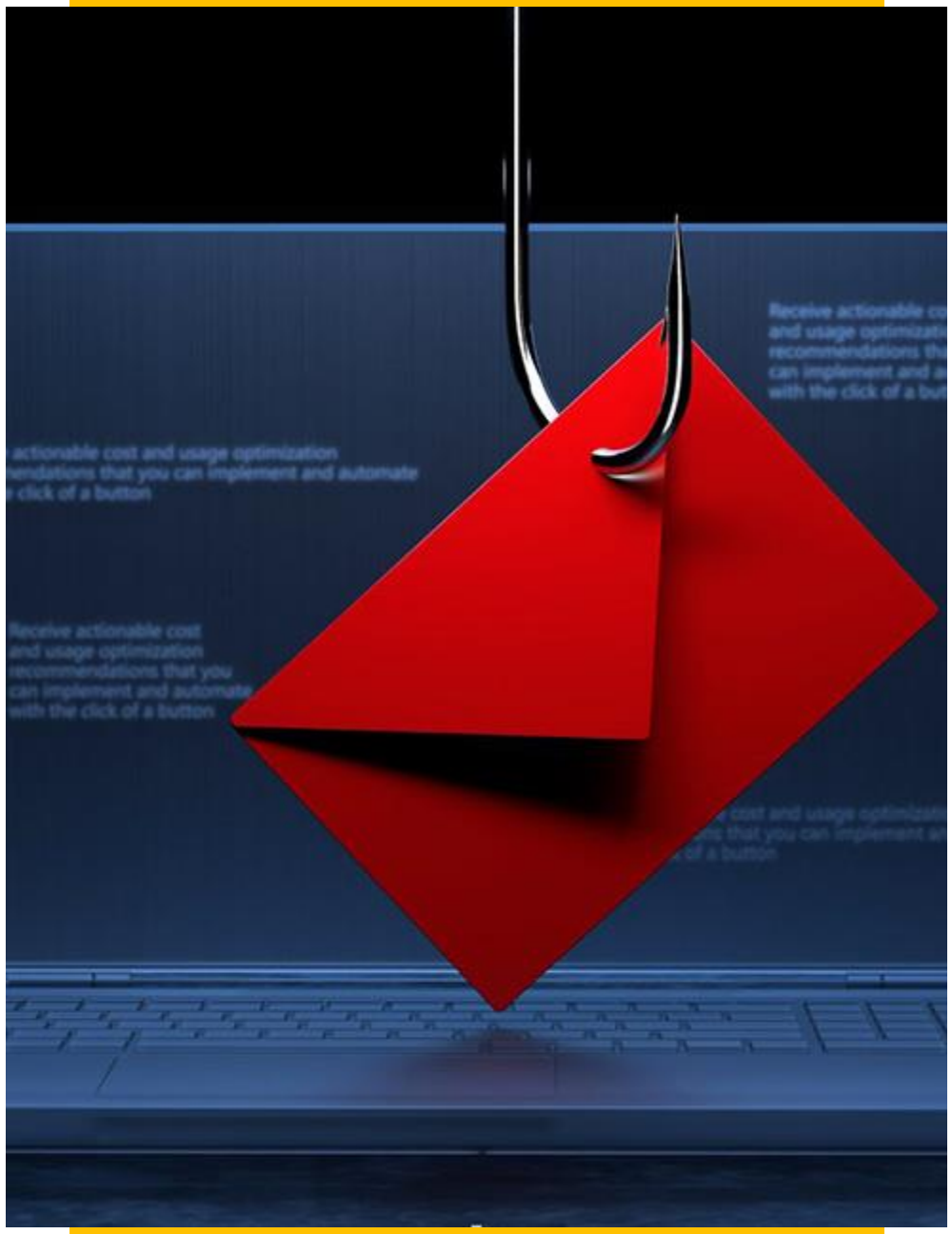
Credential Stuffing

- The attackers use stolen username and password combinations
- They use stolen credentials to gain unauthorized access to user accounts on other websites
- This attack takes advantage of the fact that many individuals reuse the same usernames and passwords across multiple online platforms



Malvertising

- Malvertising, a portmanteau of "malicious" and "advertising,“
- It involves the distribution of malicious software (malware) through online advertisements.
- In a malvertising attack, malicious code or links to malicious websites are embedded within legitimate-looking ads.



SPAMMING

- Spamming refers to the practice of sending unsolicited and often repetitive messages.
- The intention is for promoting products, services, or other content.
- Spam messages are usually sent in bulk to a large number of recipients.
- The term "spam" can also refer to unwanted and irrelevant content posted on online.